

Informe de Gestión de Incidente de Seguridad – Vulnerabilidad SQL Injection

Introducción

El presente informe documenta la identificación y explotación controlada de una vulnerabilidad de tipo SQL Injection en la aplicación web Damn Vulnerable Web Application (DVWA), utilizada con fines educativos y de laboratorio.

La prueba fue realizada en un entorno virtual controlado sobre Debian Linux, con el objetivo de comprender el funcionamiento de este tipo de vulnerabilidades y evaluar su impacto sobre la seguridad de una aplicación web y su base de datos.

Descripción del Incidente

Durante el análisis de seguridad realizado sobre DVWA, se identificó una vulnerabilidad de inyección SQL en el módulo “SQL Injection”.

La aplicación permitía el ingreso de datos sin una validación adecuada, posibilitando la modificación de las consultas SQL ejecutadas por el servidor.

Esta vulnerabilidad permite a un atacante manipular consultas a la base de datos y acceder a información sensible sin autorización.

Proceso de Reproducción

Entorno utilizado

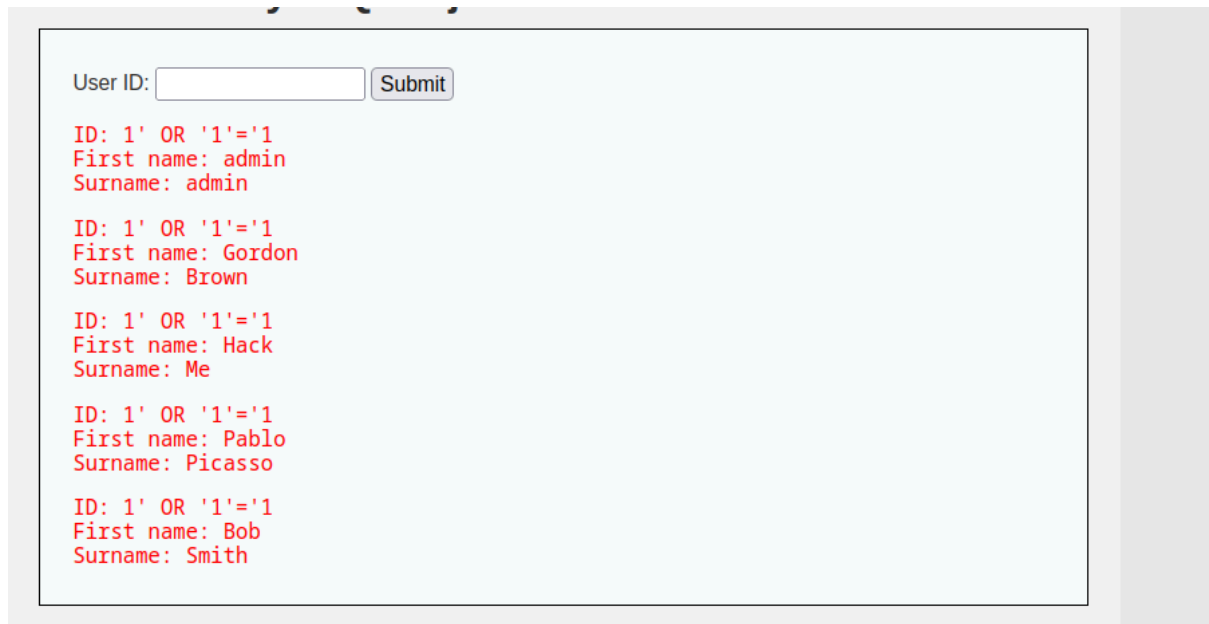
- Sistema Operativo: Debian Linux
- Aplicación vulnerable: DVWA
- Servidor web: Apache2
- Base de datos: MariaDB/MySQL
- Navegador web local

Procedimiento realizado

1. Se instaló y configuró DVWA en un entorno Debian virtualizado.
2. Se configuró la conexión con la base de datos MariaDB.
3. Se accedió al módulo “SQL Injection”.
4. En el campo “User ID” se ingresó el siguiente payload: 1' OR '1'='1

5. Al ejecutar la consulta, la aplicación devolvió múltiples registros de usuarios almacenados en la base de datos.

Esto confirmó que la aplicación era vulnerable a SQL Injection. Como se observa en la imagen.



Impacto del Incidente

La explotación exitosa de esta vulnerabilidad podría permitir a un atacante:

- Acceder a información confidencial almacenada en la base de datos.
- Obtener usuarios y credenciales.
- Modificar o eliminar información sensible.
- Comprometer la integridad de la aplicación.
- Escalar privilegios dentro del sistema.
- Afectar la disponibilidad y confiabilidad del servicio.

La vulnerabilidad representa un riesgo crítico para la confidencialidad, integridad y disponibilidad de la información.

Recomendaciones

Con base en los resultados obtenidos, se recomienda implementar las siguientes medidas de seguridad:

1. Uso de Prepared Statements

Implementar consultas parametrizadas para evitar que los datos ingresados por el usuario sean interpretados como instrucciones SQL.

2. Validación de Entradas

Aplicar validaciones estrictas sobre todos los datos recibidos desde formularios web.

3. Principio de Mínimos Privilegios

Limitar los permisos de los usuarios de base de datos únicamente a las funciones necesarias.

4. Auditorías de Seguridad

Realizar pruebas de penetración y análisis de vulnerabilidades periódicamente.

5. Capacitación del Personal

Capacitar a desarrolladores y administradores sobre desarrollo seguro y vulnerabilidades OWASP.

Conclusión

La identificación y explotación de la vulnerabilidad SQL Injection en DVWA demuestra la importancia de implementar controles de seguridad adecuados durante el desarrollo de aplicaciones web.

Las vulnerabilidades de inyección continúan siendo una de las amenazas más críticas en entornos web modernos y pueden provocar accesos no autorizados a información sensible.

La aplicación de buenas prácticas de desarrollo seguro, controles de validación y auditorías periódicas resulta fundamental para reducir riesgos y fortalecer la seguridad de los sistemas de información.